C4 NÍVEL 1

SECURITY HARDENED

Munaya E-Commerce — Contexto de Sistema & Perímetro de Segurança

Visão geral da plataforma, atores, conexões externas e fronteiras de confiança criptográficas

Projeto: Munaya Rocks E-Commerce
Status: Produção Hardened | Outubro 2026

Pessoa / Usuário (Cliente, Lojista) · **Sistema Seguro** (Plataforma Munaya) · **Sistemas Externos** (Gateways, Fábrica POD, BaaS) · **Canal Criptografado** (TLS 1.3 / HMAC) · **Barreira de Proteção** (Anti-Tampering)

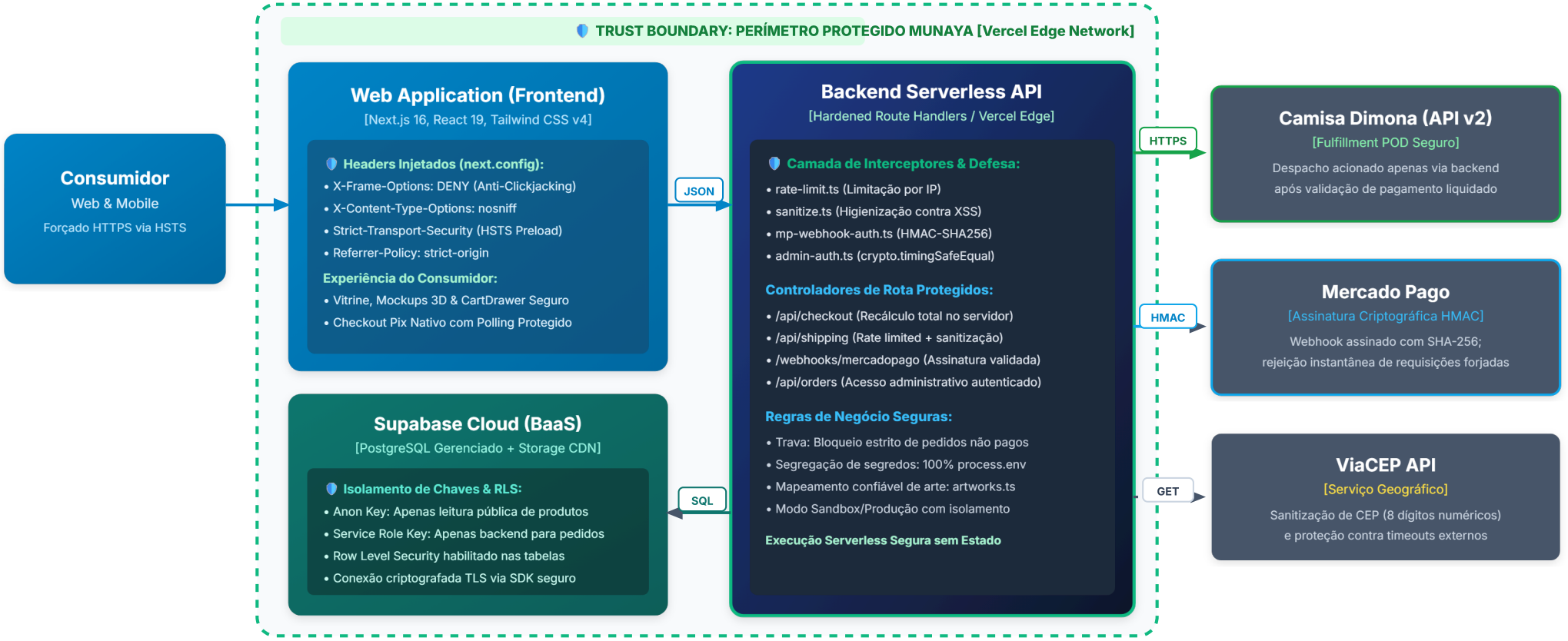


Munaya E-Commerce — Contêineres & Zonas de Confiança

Mapeamento de contêineres, cabeçalhos de segurança, middlewares e isolamento de segredos

Perímetro: Vercel Edge + Supabase Cloud
HSTS: max-age=63072000; preload

Frontend / SPA (React 19 / Next.js) | **Backend Hardened** (Rate Limit & Auth) | **Banco de Dados (RLS)** (Postgres + CDN) | **Serviços Externos Validados**



C4 NÍVEL 3

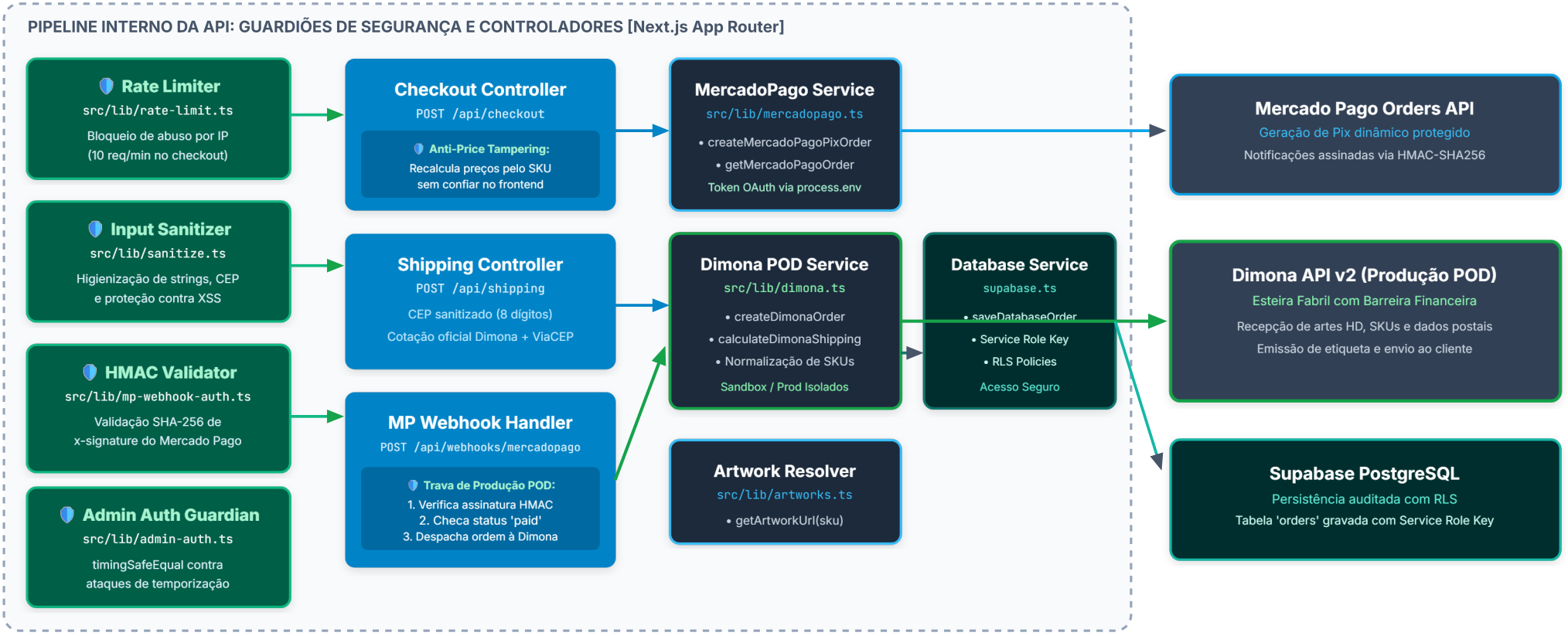
COMPONENTES DE SEGURANÇA

Munaya E-Commerce — Componentes de Segurança e Route Handlers

Middlewares perimetrais, validação de tokens, filtros criptográficos e fluxo até a fábrica

Módulos: src/lib/rate-limit, sanitize, mp-webhook-auth, admin-auth
Padrão: Interceptor Guardrail Pipeline

Guardiões de Segurança (Interceptores) | API Route Handlers (Controladores) | Services Internos (Negócio) | Sistemas Terceirizados



C4 NÍVEL 4 / MATRIZ

MATRIZ DE DEFESA

Matriz de Conexões Externas & Controles de Segurança

Especificações criptográficas, integridade de transações, tolerância a falhas e políticas de defesa

Padrão: REST / HMAC-SHA256 / RLS
Conformidade: LGPD & OWASP Top 10

Sistema Externo	Responsabilidade	Protocolo	Mecanismo de Autenticação	Camada de Segurança Específica	Tratamento de Falha / Resiliência
Camisa Dimona Fulfillment POD	Confecção DTG sob demanda, embalagem, despacho postal e frete fabril.	HTTPS / REST `TCP 443`	API Key via Header `Bearer DIMONA_API_KEY`	Trava Financeira Prévia A API fabril só é acionada após o webhook validar status de pagamento liquidado no gateway.	Modo Sandbox com bypass controlado se a chave estiver ausente; log de auditoria estruturado.
Mercado Pago Payment Gateway	Ordens Pix dinâmicas com QR Code Copia e Cola e notificação de liquidação.	HTTPS / REST `TCP 443`	OAuth Bearer Token `APP_USR-...`	HMAC-SHA256 Webhook Validação estrita de `x-signature` e `x-request-id` ; rejeição de webhooks forjados.	Processamento idempotente com deduplicação por `external_reference` ; retries automáticos.
Supabase Data & Storage	PostgreSQL relacional e Object Storage público para mockups e imagens.	HTTPS / WSS `TCP 443 / 5432`	Anon Key (Navegador) Service Role Key (Servidor)	Row Level Security (RLS) Tabelas de pedidos só aceitam escrita a partir do backend autenticado via Service Role Key.	Fallback seguro para catálogo local se o banco falhar; reconexão automática com backoff via SDK.
ViaCEP Geolocalização	Resolução instantânea de logradouro e UF para frete e checkout.	HTTPS / REST `TCP 443`	Pública / Sem Auth	Input Sanitization Higienização estrita de CEP (`replace(/\D/g, '')`) com validação de 8 dígitos.	Falha graciosa: se o ViaCEP estiver indisponível, o cliente digita o endereço sem travar a compra.

Anti-Price Tampering

O total do pedido é recalculado integralmente no servidor (`route.ts`) multiplicando os preços oficiais dos SKUs. O valor enviado pelo navegador é ignorado.

Rate Limiting por IP

Implementado em `rate-limit.ts` : limita requisições consecutivas nos endpoints de checkout (10/min) e frete (30/min), mitigando ataques de força bruta e DDoS.

Constant-Time Auth

No painel `/admin` , a comparação de senhas e tokens utiliza `crypto.timingSafeEqual` em `admin-auth.ts` , prevenindo ataques de temporização.

Hardening de Headers HTTP

Configurado no `next.config.ts` : HSTS Preload (2 anos), `X-Frame-Options: DENY` contra Clickjacking, `nosniff` e políticas restritivas de referrer.

Conformidade e Responsabilidade Operacional (Dimona POD): Conforme registrado em `docs/fornecedores.md` : Defeitos de confecção fabril são cobertos pela Dimona em até 7 dias corridos. Trocas comerciais ou arrependimento (CDC Art. 49) são geridas pela Munaya. O pipeline automatizado garante que nenhum custo de confecção seja gerado antes da liquidação financeira definitiva.